Software Engineering

Lab 5: Static Code Analysis

Name: Shreya C Rao

SRN: PES2UG24CS481

Sem: 5

Sec: H

BEFORE:

```
(venv) C:\Users\Shreya C Rao\L5_42_student_grade_system>python student_grade_system.py
Is S01 passing: True
Calculated GPA: 4.35
Student Hash: 4cfe35d8825ba802868fabe687dc860d
Registration PIN: 4086
Grade sheet exported to: grade_sheet.txt
Portal token active: ADMIN_GRADE_PORTAL_TOKEN_2026
```

1)Pylint report

```
(venv) C:\Users\Shreya C Rao\L5_42_student_grade_system>type reports\before\pylint_report.txt
************* Module student_grade_system
student_grade_system.py:75:0: C0304: Final newline missing (missing-final-newline)
student_grade_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:15:0: C0103: Function name "addGrade" doesn't conform to snake_case naming style (invalid-name)
student_grade_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
student_grade_system.py:19:22: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
student_grade_system.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:26:4: W0702: No exception type(s) specified (bare-except)
student_grade_system.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:32:7: C0121: Comparison 'gradebook.get(student_id) == None' should be 'gradebook.get(student_id) is None' (sin
gleton-comparison)
student_grade_system.py:35:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
student_grade_system.py:35:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-re
turn)
student_grade_system.py:31:4: W0612: Unused variable 'grace_marks' (unused-variable)
student_grade_system.py:41:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:44:10: W0123: Use of eval (eval-used)
student_grade_system.py:43:4: W0612: Unused variable 'avg_score' (unused-variable)
student_grade_system.py:48:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:52:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:56:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:57:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
student_grade_system.py:57:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
student_grade_system.py:63:0: C0116: Missing function or method docstring (missing-function-docstring)
student_grade_system.py:6:0: W0611: Unused import json (unused-import)

-----------------------------------
Your code has been rated at 5.51/10
```

2)bandit report

```
(venv) C:\Users\Shreya C Rao\L5_42_student_grade_system>type reports\before\bandit_report.txt
Run started:2026-10-14 06:42:55.978638+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\student_grade_system.py:26:4
25              gradebook[student_id]["attendance"] += present_days
26          except:
27              pass
28

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\student_grade_system.py:44:10
43          avg_score = sum(marks) / len(marks)
44          gpa = eval(gpa_expr)
45          return gpa

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\student_grade_system.py:49:11
48      def generate_student_hash(student_id):
49          return hashlib.md5(student_id.encode()).hexdigest()
50

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
```

```
   Location: .\student_grade_system.py:53:11
52      def generate_registration_pin():
53          return random.randint(1000, 9999)
54

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\student_grade_system.py:60:4
59          f.close()
60          os.system("echo Grade sheet exported to: " + filename)
61

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'ADMIN_GRADE_PORTAL_TOKEN_2026'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\student_grade_system.py:64:19
63      def main():
64          portal_token = "ADMIN_GRADE_PORTAL_TOKEN_2026"
65          addGrade("S01", 95)

--------------------------------------------------

Code scanned:
        Total lines of code: 55
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 3
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
```

```
                Undefined: 0
                Low: 0
                Medium: 1
                High: 5
Files skipped (0):
```

3)Flake8 report

```
(venv) C:\Users\Shreya C Rao\L5_42_student_grade_system>type reports\before\flake8_report.txt
student_grade_system.py:6:1: F401 'json' imported but unused
student_grade_system.py:19:80: E501 line too long (81 > 79 characters)
student_grade_system.py:26:5: E722 do not use bare 'except'
student_grade_system.py:31:5: F841 local variable 'grace_marks' is assigned to but never used
student_grade_system.py:32:34: E711 comparison to None should be 'if cond is None:'
student_grade_system.py:34:80: E501 line too long (83 > 79 characters)
student_grade_system.py:43:5: F841 local variable 'avg_score' is assigned to but never used
student_grade_system.py:75:7: W292 no newline at end of file
```

AFTER:

```
(venv) C:\Users\Shreya C Rao\L5_42_student_grade_system>python student_grade_system.py
Is S01 passing: True
Calculated GPA: 4.35
Student Hash: ac7438e86cb85ebd90f4d0abb235f9a28f112e1ec0b7995156f3d5e868d315f8
Registration PIN: 8171
Grade sheet exported to: grade_sheet.txt
```

1)Pylint report

```
(venv) C:\Users\Shreya C Rao\L5_42_student_grade_system>pylint student_grade_system.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 5.51/10, +4.49)
```

2)bandit report

```
(venv) C:\Users\Shreya C Rao\L5_42_student_grade_system>bandit -r student_grade_system.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.15
Run started:2026-10-14 14:06:19.977049+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 61
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

3)Flake8 report

```
(venv) C:\Users\Shreya C Rao\L5_42_student_grade_system>flake8 student_grade_system.py
```

Issues table:

Issue	Type	Line(s)	Description	Fix Approach
MD5 hashing (hashlib.md5)	Security — High	49	Bandit B324 identified the use of a weak hashing algorithm.	Replaced MD5 with SHA-256 using hashlib.sha256().
Shell command execution (os.system)	Security — High	60	Bandit B605 flagged shell execution, which can introduce command-execution risks.	Removed the shell command and printed the export message directly in Python.
Use of eval()	Security — Medium	44	Bandit B307 and Pylint W0123 flagged evaluation of a string as Python code.	Removed eval() and calculated the GPA directly using numeric operations.
Predictable random PIN	Security — Low	53	Bandit B311 flagged the use of the standard pseudo-random generator for a PIN.	Replaced random.randint() with secrets.randbelow().
Hard-coded portal token	Security — Low	64	Bandit B105 flagged a token-like string embedded in the source code.	Removed the hard-coded token demonstration.
Mutable default list argument	Bug risk	15	Pylint W0102 flagged an empty list as a default argument, which can retain shared state between function calls.	Changed the default to None and initialized a new list inside the function.

Bare exception with ignored error	Reliability / Code quality	26–27	Bandit B110, Pylint W0702, and Flake8 E722 flagged a broad exception handler that silently ignored errors.	Removed the broad exception-handling pattern and validated inputs.
File handling without explicit encoding or context manager	Reliability	57	Pylint W1514 and R1732 flagged missing explicit encoding and the absence of a context manager.	Used with open(filename, "w", encoding="utf-8") to ensure the file closes automatically.
Unused imports, variables, and style issues	Code quality / Style	6, 19, 31, 32, 34, 43, 75	Pylint and Flake8 reported an unused json import, unused variables, comparison to None, long lines, and a missing final newline.	Removed unused names, used is None, wrapped long lines, and added a final newline.